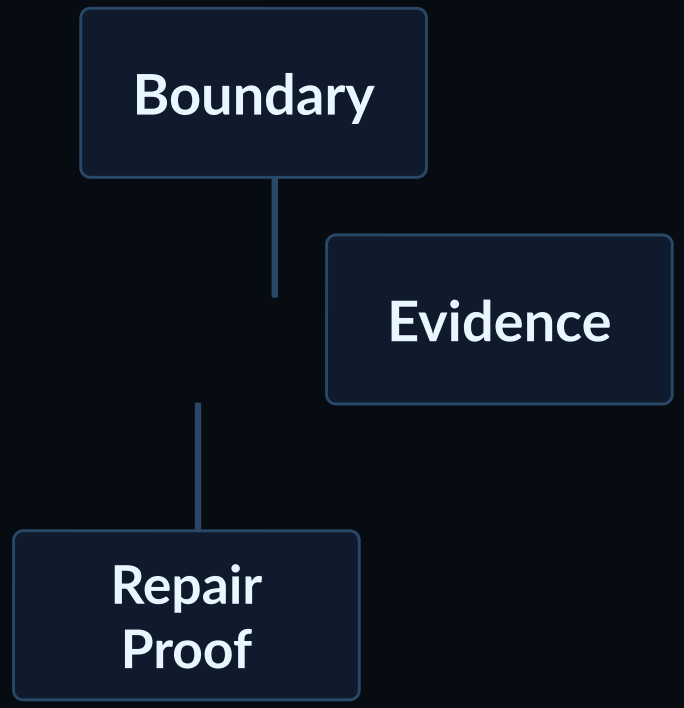
AI 軟體醫材的資安實戰

Boundary -> Evidence -> Decision -> Repair proof



林家聖 | CYBERSEC 2026

免責聲明 Disclaimer

CYBERSEC 議程之簡報與相關素材僅供教育與交流目的使用，與會者應自行判斷其適用性。
講者、贊助商或與會者於演講或討論中所表達之事實、觀點與立場，均屬其個人意見；
除非另有明確說明，皆不代表 CYBERSEC 或主辦單位之立場。
CYBERSEC 不對所呈現內容之正確性、完整性或可能產生之影響負責，
亦不對任何資訊予以背書或作出保證。

The presentations and materials at CYBERSEC are provided solely for educational.
Attendees should independently assess the applicability of any information presented.
Any facts, opinions, or views expressed by speakers, sponsors, or participants are their own and,
unless expressly stated otherwise, do not represent the views of CYBERSEC or the event organizers.
CYBERSEC assumes no responsibility for the accuracy or completeness of the content,
any consequences arising from its use,
and does not provide any endorsement or warranty regarding the information presented.

你賣的不是模型

Workflow

Repair

Evidence

AI is becoming care infrastructure

Model

Runtime

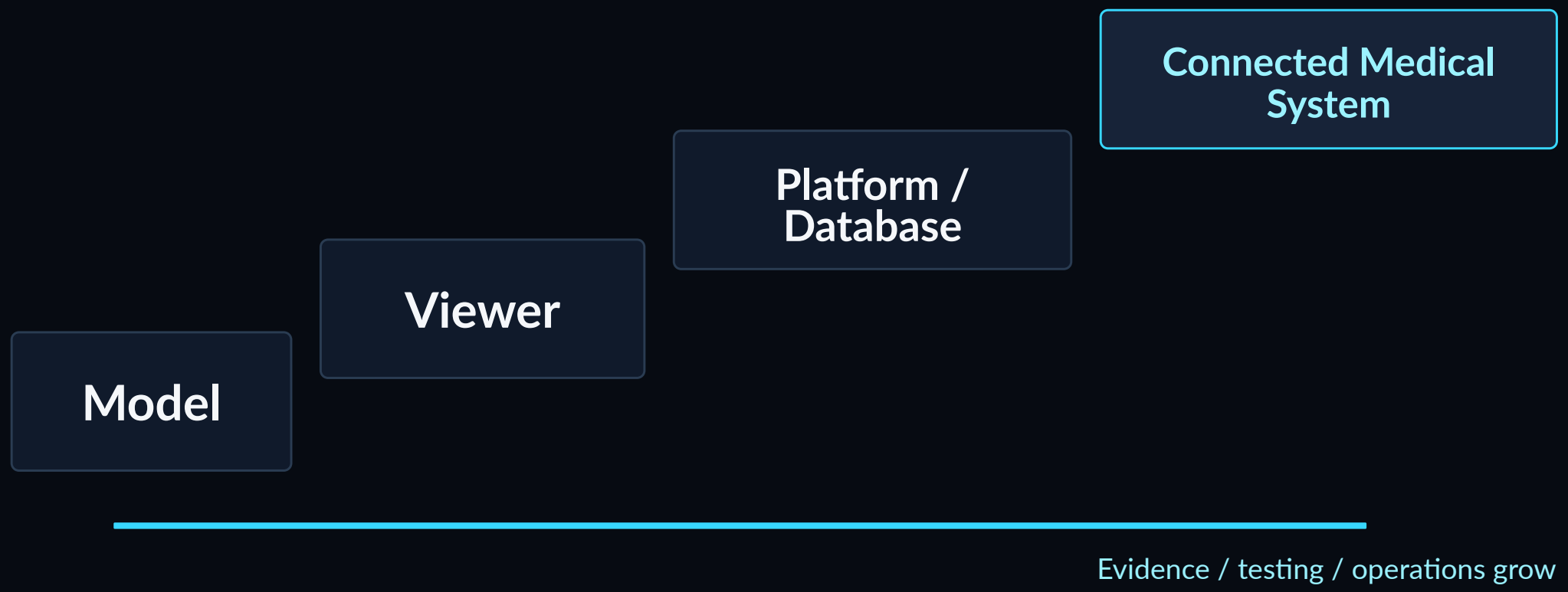
Data / Identity

Update / Support

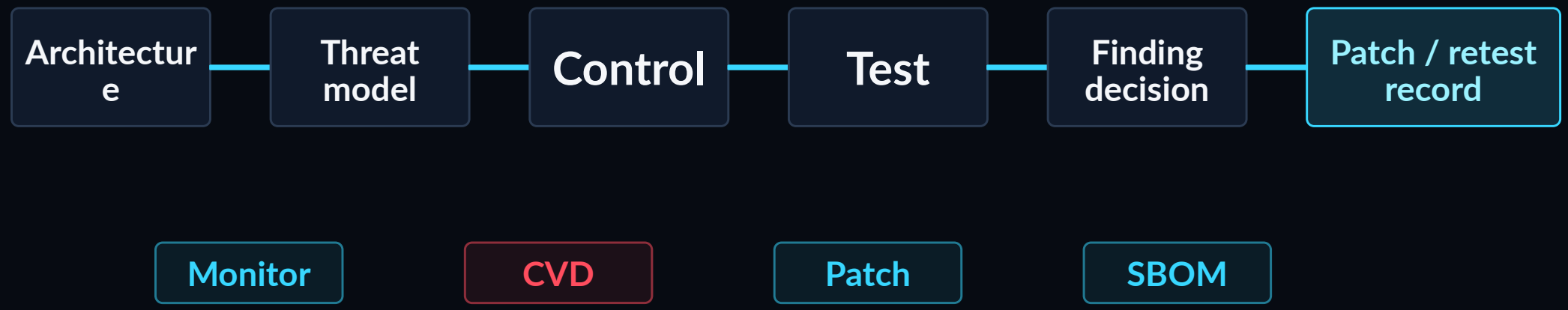
Clinical continuity

Service interruption -> care workflow delay

Product boundary decides risk



From obligation to evidence chain



Three Risk Layers, One Governance Language

Model behavior

- Intended use
- Data / V&V
- Limits

Software stack

- Provenance
- Isolation
- Updates

Clinical workflow

- User roles
- Continuity
- Residual risk

Scale 1-2: Artifact to User-Facing System

Model

- Artifact
- Data lineage
- SBOM
- Update boundary

Viewer

- Parser
- Upload
- Cache
- Output interpretation

Scale 3-4: Platform to Clinical Continuity

Platform / Database

- Identity
- API
- Database
- Audit log
- Backup

Connected Medical System

- PACS / HIS
- Hospital network
- Update server
- Remote service
- Downtime fallback

Cyber Safety Is Patient Safety

Availability

Integrity

Repairability

Testing Portfolio: What Question Does Each Test Answer?

SBOM / SCA
components?

White-box
fix before release?

Fuzz / abuse
what breaks?

Black-box
exposed from outside?

Pen test
can issues chain?

Retest
did repair work?

Patch SLA

Every finding needs a decision

Owner | Severity | Due date

Intake — Triage — **Decision** — Patch — Retest — Archive

Fix now | Compensate | Defer | Not applicable

Small Team 30 / 60 / 90

30

Inventory
SBOM
data flow

60

Threat model
CI gates
finding workflow

90

Pen test
Patch SLA
retest evidence

先把安全做進產品
法規文件才會自然長出來

Build trust before the audit